

Cloud Security Operations & Incident Response

Centralized Logging & Automated Alerting, GuardDuty Security Monitoring, a Security Dashboard, and a Tested Cloud Incident Response Playbook

Scenario organization: Horizon Valley Medical Center (HVMC)

Capstone project: AccessGuard Health — Azure/Entra ID & AWS IAM Operations

Rubric item: Cloud Security Operations & Incident Response (Cloud Security 1)

Builds on: Compliance Auditing Basics, Documentation & Reporting, Legal & Ethical Implementation, and Cloud Compliance & Governance Controls submissions for this same AWS environment

Report date: October 6, 2026

Created by: Sabitha S Karanavar

This submission is prepared as a classroom lab exercise for the HVMC simulation used in this capstone. Configuration descriptions and the incident response test below are illustrative/simulated against the lab's AWS environment and do not describe a live production account or an actual security incident.

Rubric Cross-Reference

Rubric Requirement	Where Addressed
Configure centralized logging using CloudTrail and VPC Flow Logs with automated alerting for security events	Section 1 — Centralized Logging & Automated Alerting
Implement security monitoring using GuardDuty or equivalent tools	Section 2 — Security Monitoring (GuardDuty)
Create security dashboards with key metrics	Section 3 — Security Dashboard
Develop and test a cloud incident response playbook covering identification, containment, investigation, eradication, and recovery, with evidence of playbook testing and documentation	Section 4 — Cloud Incident Response Playbook & Tabletop Test

This submission completes the AWS governance arc built across this project's compliance series: the log-retention gap identified in *HVMC_Compliance_Auditing_Basics.pdf* is closed by the CloudTrail retention configuration in Section 1; the AWS Organizations structure from *HVMC_Cloud_Compliance_and_Governance_Controls.pdf* hosts the GuardDuty delegated administrator in Section 2; and the incident response playbook in Section 4 is tested directly against the same "orphaned AWS IAM account" incident scenario documented in *HVMC_Legal_and_Ethical_Implementation.pdf* (Section 4), rather than a generic, disconnected example.

1. Centralized Logging & Automated Alerting

1.1 CloudTrail

- An **organization trail** is enabled from the Security OU (delegated administrator), applying to every account under the Production-Workloads and Sandbox OUs established in the Cloud Compliance & Governance Controls submission, so no member account can opt out of logging.
- Multi-region, with log file validation enabled (SHA-256 digest files) to detect tampering, capturing both management events and S3 data events (data events scoped to the buckets holding ePHI-adjacent exports).
- Delivered to both an encrypted S3 bucket (long-term storage) and a CloudWatch Logs group (real-time query and alerting) in parallel.
- **Retention:** an S3 lifecycle policy moves CloudTrail logs to Glacier Deep Archive after 1 year and expires them at 6 years, directly closing the log-retention finding (Control 2) from the Compliance Auditing Basics audit.

1.2 VPC Flow Logs

- Enabled at the VPC level (all subnets/ENIs in scope) with traffic type **ALL**, so both accepted and rejected connections are captured — rejected-connection volume is what feeds the security dashboard in Section 3.
- Delivered to the same CloudWatch Logs group family as CloudTrail so both can be queried together with CloudWatch Logs Insights during an investigation (used directly in the Section 4 playbook test).

1.3 Automated Alerting

Triggering Event	Source	Mechanism	Notification Target	Severity
Root account sign-in or API use	CloudTrail	EventBridge rule	SNS: security-critical	CRITICAL
IAM policy or SCP change	CloudTrail	EventBridge rule	SNS: security-high	HIGH
Security group opened to 0.0.0.0/0 on a sensitive port	Config / CloudTrail	EventBridge rule	SNS: security-high	HIGH
GuardDuty finding, severity 7.0 or above	GuardDuty	Native EventBridge integration	SNS: security-critical	CRITICAL
Spike in VPC Flow Log REJECT entries	VPC Flow Logs	CloudWatch Logs metric filter + alarm	SNS: security-medium	MEDIUM

Each SNS topic fans out to the on-call Incident Response channel (acting role) and is logged to the same evidence repository used for the Documentation & Reporting submission's record-management procedures.

2. Security Monitoring (GuardDuty)

2.1 Configuration

Amazon GuardDuty is enabled organization-wide with its delegated administrator seated in the Security OU (the same OU hosting the CloudTrail organization trail), and set to auto-enable for any new account added to the organization. Foundational data sources (CloudTrail management/data events, VPC Flow Logs, DNS query logs) are supplemented with S3 Protection, RDS Protection, and Malware Protection for EC2/EBS.

2.2 Finding Categories Monitored

Finding Type	What It Indicates	Severity	Initial Response
Policy:IAMUser/RootCredentialUsage	The root account was used instead of a named IAM identity	CRITICAL	Immediate escalation to Incident Commander
UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration	Credentials from an EC2 instance role are being used outside the instance	HIGH	Suspend the credential; begin containment (Section 4)
Recon:IAMUser/MaliciousIPCaller	API calls from an IP on a known-malicious threat list	MEDIUM	Investigate source and affected principal
Backdoor:EC2/C&CActivity.B	An instance is communicating with a known command-and-control host	CRITICAL	Isolate the instance immediately
CryptoCurrency:EC2/BitcoinTool.B	An instance is running cryptocurrency-mining software	HIGH	Isolate and snapshot for investigation

2.3 Integration with Alerting

GuardDuty findings publish natively to EventBridge, which routes Medium-and-above findings into the same SNS-based alerting pipeline built in Section 1.3 — GuardDuty does not run as an isolated tool with its own separate notification path.

3. Security Dashboard

A CloudWatch Dashboard, `HVMC-Security-Operations` , gives the IAM/Identity Administrator and Compliance Auditor one screen covering logging health, active threats, and governance compliance together:

GuardDuty Findings by Severity

7-day rolling count,
Low/Medium/High/Critical — source:
GuardDuty

CloudTrail Event Volume

Events/hour with an anomaly band, flags
unusual API activity spikes — source:
CloudTrail via CloudWatch Logs

Config Compliance Ratio

Compliant vs. non-compliant resources
against the rules in the Governance
Controls submission — source: AWS
Config

Failed / Root Console Logins

Count of failed sign-ins and any root
logins in the period — source: CloudTrail

VPC Flow Log Rejected Connections

Rolling count of REJECT entries, the
input to the Section 1.3 spike alarm —
source: VPC Flow Logs

Open Remediation Findings

Same KPI as the Documentation &
Reporting quarterly report, by risk rating
— source: remediation tracker

Metric	Refresh Cadence	Owner
GuardDuty findings, CloudTrail volume, Flow Log rejects	Near real-time (5 min)	IAM/Identity Administrator (on-call)
Config compliance ratio	Hourly (on each Config evaluation)	IAM/Identity Administrator
Open remediation findings	Weekly	Compliance Auditor

4. Cloud Incident Response Playbook & Tabletop Test

4.1 Playbook Procedures

1. Identification

Objective: confirm a security event has occurred and establish its scope.

Key actions: triage the GuardDuty/CloudTrail alert from Sections 1–2; confirm the affected account, resource, and principal; assign an incident severity and open an incident ticket; notify the Incident Commander (acting role).

Evidence: GuardDuty finding ID, CloudTrail event ID, incident ticket number.

2. Containment

Objective: limit further damage without destroying evidence.

Key actions: suspend (not delete) the implicated IAM credential; attach a quarantine policy denying all further actions by that principal; snapshot affected resources before any further change; rotate any secrets the credential could have reached.

Evidence: timestamp of credential suspension, quarantine policy ARN, snapshot IDs.

3. Investigation

Objective: determine root cause, scope of access, and whether ePHI was involved.

Key actions: pull the full CloudTrail event history for the identified principal; cross-reference VPC Flow Logs for associated network activity; apply the HIPAA four-factor breach risk assessment (45 CFR §164.402, as used in the Legal & Ethical Implementation submission) to determine reportability; preserve a documented chain of custody for all evidence collected.

Evidence: CloudTrail Lake query export, Flow Log excerpt, completed breach risk assessment.

4. Eradication

Objective: remove the attacker's access and the underlying root cause.

Key actions: fully deprovision the compromised/orphaned credential (not just suspend it); confirm the SCP and tagging controls from the Governance Controls submission would prevent an equivalent unowned account going forward; re-run the relevant AWS Config Rule to confirm the resource is now compliant.

Evidence: IAM deprovisioning confirmation, Config re-evaluation result (COMPLIANT).

5. Recovery

Objective: restore normal operations with confidence the issue will not recur.

Key actions: reissue any legitimate access under new, correctly-owned, least-privilege credentials; place the affected resources under a 14-day heightened-monitoring window on the Section 3 dashboard; close the incident ticket; update the

remediation tracker; carry a lessons-learned summary into the next quarterly compliance status report.

Evidence: closure timestamp, updated remediation tracker entry, lessons-learned note.

4.2 Playbook Test — Tabletop Exercise

This playbook was tested as a tabletop exercise walking the exact scenario documented in the Legal & Ethical Implementation submission (Section 4): *Unauthorized Access via an Orphaned AWS IAM Account*. The table below is the test record, retained as the evidence of playbook testing this rubric item asks for.

Elapsed Time	Phase	Action Taken	Participant (acting role)	Outcome
T+0 min	Identification	GuardDuty finding and CloudTrail alert reviewed; incident ticket opened	IR Analyst	Confirmed as a Security Incident
T+5 min	Containment	Orphaned IAM credential's access keys suspended; quarantine policy attached	IAM/Identity Administrator	No further API activity observed from the principal
T+20 min	Investigation	Full CloudTrail event history pulled for the principal; HIPAA four-factor breach test applied	Compliance Auditor	Breach presumption not rebutted — classified Reportable, matching Legal & Ethical §4.1
T+45 min	Eradication	Orphaned account fully deprovisioned; Require-Resource-Tags/Owner enforcement re-confirmed	IAM/Identity Administrator	Config re-evaluation returned COMPLIANT
T+60 min	Recovery	Incident closed; remediation tracker updated; 14-day heightened-monitoring window opened	Compliance Auditor	Normal operations confirmed; lessons learned logged

4.3 Test Documentation & Lessons Learned

The test confirmed all five phases executed in the stated order and within a 60-minute window end to end. One improvement was identified: containment currently requires a manual step to suspend credentials, which could be automated with an SSM Automation runbook triggered directly from the Section 1.3 EventBridge rule, cutting the containment step from 5 minutes to under 1. This test record — the phase table above, with its timestamps and participants — is itself retained under the 6-year record-retention schedule established in the Documentation & Reporting submission, as the playbook's evidence of testing.

Sources: *HVMC_Compliance_Auditing_Basics.pdf*, *HVMC_Legal_and_Ethical_Implementation.pdf*, and *HVMC_Cloud_Compliance_and_Governance_Controls.pdf* (companion submissions). Prepared as the Cloud Security Operations & Incident Response deliverable for the Semester 4 Healthcare IAM Operations Home Lab capstone.